

14 - project proposal

Recon on a cyber target

ai autonomous reconnaissance for red team operations

queen's university, ai & data science master's program - graduation project proposal

team members:

Name	Role
elsayed elmandoh	nlp engineer and agentic ai engineer
mohamed kamal	ai engineer and offensive security engineer
mostafa elofy	ai engineer and threat intelligence engineer
mohamed zidan	ai engineer and adversarial ai

executive summary

modern penetration testing and red team operations are bottlenecked at the reconnaissance phase. analysts spend hours manually chaining together osint tools, cross-referencing results from a dozen sources, and building target profiles by hand - a process that is slow, error-prone, and difficult to scale. this project builds an ai-driven multi-agent system that autonomously executes the full initial reconnaissance phase: from a single domain name, the system queries 8+ intelligence sources, reasons adaptively about findings, and produces a structured target profile in under 10 minutes. the tool is designed exclusively for authorized red team use, with a strict scope validator preventing any out-of-scope queries. success is measured against manually-built ground truth profiles across 5 authorized targets, targeting 85%+ recall on discovered assets.

problem

the reconnaissance phase of an authorized penetration test requires correlating data from dns records, certificate transparency logs, shodan, censys, github, whois, virustotal, and email harvesting apis - none of which are natively integrated. a skilled analyst doing this by hand takes 2-6 hours per target and still misses cross-source correlations. adversaries have been automating this for years. authorized red teams and researchers have not caught up.

there is no unified, intelligent agent that orchestrates multi-source osint, adapts based on what it discovers, and synthesizes findings into a structured target profile without constant human intervention.

proposed solution

a multi-agent system built on crewai, where:

- a **planner agent** receives a target domain, decomposes the recon task, and delegates to specialized sub-agents via a react reasoning loop (observe → reason → act)
- **7 specialized sub-agents** each own one data source: dns, subdomain enumeration, network/port intelligence, whois/asn, github dorking, reputation, and email harvesting
- a **scope validator** blocks any query outside the user-defined target scope before execution

- a **synthesis agent** deduplicates, correlates, and risk-scores all findings, then renders a machine-readable json profile and human-readable markdown report

the critical differentiator is adaptive replanning: if the dns agent discovers an aws s3 bucket pattern, the planner dynamically adds a follow-up enumeration task. this simulates how a real threat actor reasons through initial recon - not a static checklist.

technical approach

architecture

```
user input → scope validator → planner agent (react loop)
  → [dns | subdomain | network | whois | socmint | reputation | email] agents
  → structured json outputs (pydantic typed)
  → synthesis agent (dedup + correlate + risk score)
  → target_profile.json + target_report.md
```

stack

layer	technology
agent framework	crewai
llm (planner + synthesis)	llama-3.1-8b (configurable: qwen2.5-7b)
data schemas	pydantic v2
osint libraries	dnspython, shodan, censys, ipwhois, pygithub
async execution	asyncio (max 4 concurrent sub-agents)
cli	prompt_toolkit
output formats	json + jinja2 markdown templates

all llm inference runs locally via ollama - no external api calls, no cost, no data leakage. runs on a developer laptop (cpu inference, no gpu required for 8b models).

data strategy

no training dataset. the system consumes live osint from 8 public apis at runtime:

source	data type
crt.sh	certificate transparency / subdomains
shodan	exposed ports, services, banners
censys	tls certificates, host data
virustotal	domain/ip reputation, passive dns
whois + ipwhois	ip ownership, asn, registrar
dnspython	a/mx/ns/txt/aaaa records
github search api	leaked secrets, config refs
hunter.io	email addresses

for evaluation: manually-built ground truth target profiles for 5 authorized targets (ctf domains, personal lab, public bug bounty scopes). precision/recall/f1 computed against these baselines.

constraints & ethics

must do: - scope validation before every sub-agent call - zero tolerance for out-of-scope queries - passive mode by default - no active scanning of live systems without explicit authorization - rate limit compliance for all apis - token bucket per source - full reasoning trace logged to jsonl for reproducibility

must not do: - no active probing without --active flag and user confirmation - no exploitation - this system stops at recon, period - no pii storage beyond the authorized target profile - no use against unauthorized targets - legal disclaimer enforced at startup

legal framing: passive osint against publicly available data is legally defensible for authorized security research. all test targets for this project are either personally owned, ctf environments, or explicitly public bug bounty scopes.

resources required

resource	details
compute	developer laptop (no gpu)
llm api	ollama (llama-3.1-8b - local open source)
osint apis	shodan (free), censys (researcher free), virustotal (free), github (authenticated free), crt.sh (free), hunter.io (25/month free)
authorized test targets	personal lab domain + hackthebox/tryhackme + public bug bounty scopes
development time	16 weeks, solo

estimated cost for development and evaluation: \$0 for llm inference (ollama runs locally). only potential cost is paid osint api tiers if free limits are exceeded.

risks

risk	likelihood	impact	mitigation
api rate limits blocking evaluation runs	high	medium	token bucket rate limiting + exponential backoff + multi-day eval spread
llm planner hallucinates tool calls	medium	high	strict pydantic output validation + tool call schema enforcement
scope creep: feature additions delay core delivery	medium	high	phased milestones with hard cutoffs per phase
authorized test target unavailable / changes	low	medium	5 targets provides redundancy; ctf targets are stable
github dorking yields too much noise	medium	low	relevance scoring filter before results enter planner context
legal ambiguity in testing jurisdiction	low	high	all targets pre-authorized + documented + passive-only by default

success metrics

metric	target
osint sources queried per run	≥ 8
time to complete target profile	< 10 minutes
asset recall vs ground truth	$\geq 85\%$
runs end-to-end without human input	100% of test cases
output is valid structured json	100%
adaptive replanning triggered correctly	≥ 3 scenario types detected

timeline summary

phase	weeks	deliverable
foundation	1-3	project setup, schemas, scope validator, first 3 sub-agents
agent integration	4-7	all 7 sub-agents, planner v1, rate limiting
synthesis layer	8-10	dedup, correlation, risk scoring, output rendering
adaptive planning	11-12	planner adapts on discovered intelligence
evaluation	13-14	ground truth profiles, precision/recall/f1 analysis
final delivery	15-16	documentation, demo, v1.0 release

academic contribution

this project contributes:

1. **a working open-source implementation** of an llm-orchestrated multi-source osint system - demonstrable, reproducible, and benchmarked
2. **an evaluation methodology** for measuring osint agent recall against manually-built ground truth profiles
3. **a design pattern** for scope-constrained agentic security tooling (ethical ai for security research)
4. **practical validation** of crewai + react loop for adversary simulation tasks - filling a gap in existing ai-for-security literature

the closest published work (pentestgpt, 2023) requires human tool execution. this project closes that gap with fully autonomous multi-source osint orchestration.

conclusion

recon agent operationalizes what was previously a manual, slow, analyst-intensive process into an autonomous, intelligent, scope-constrained pipeline. it is academically novel, technically rigorous, practically useful, and designed from the ground up to be used responsibly. the combination of agentic planning, multi-source osint integration, and adaptive replanning represents a meaningful step forward in ai-assisted security research tooling.